

Cybersecurity + RAG

Question Bank: Applying Retrieval-Augmented Generation to Cybersecurity

This question bank is organized into sections covering RAG fundamentals, cybersecurity-specific applications, architecture & design, data/document sourcing, evaluation, and security risks of RAG systems themselves. Use it for interview prep, project scoping, quiz creation, or as seed questions for building a QA/evaluation dataset for a cybersecurity RAG system.

1. RAG Fundamentals

- 1 What is Retrieval-Augmented Generation (RAG), and how does it differ from standard fine-tuning of an LLM?
- 2 Explain the two main stages of a RAG pipeline: retrieval and generation.
- 3 What is a vector embedding, and why is it central to retrieval in RAG systems?
- 4 Compare dense retrieval (embeddings) vs. sparse retrieval (BM25/TF-IDF) for a security knowledge base.
- 5 What is chunking, and why does chunk size/overlap matter when indexing technical security documents (e.g., NIST 800-53)?
- 6 What role does a vector database (e.g., FAISS, Pinecone, Weaviate, Chroma) play in a RAG architecture?
- 7 What is the difference between semantic search and keyword search in the context of retrieving CVE or threat intel data?
- 8 Explain re-ranking and why it might be added after the initial retrieval step.

2. Cybersecurity Applications of RAG

- 1 How could a RAG system assist a SOC analyst during incident response by retrieving relevant playbooks?
- 2 Design a RAG-based assistant that answers questions using an organization's internal security policies. What documents would you ingest?
- 3 How can RAG be used to summarize and contextualize CVE/NVD entries for a given software stack?
- 4 How would you build a RAG pipeline over MITRE ATT&CK; data to help map an observed technique to a tactic?
- 5 Describe how RAG could support automated triage of phishing emails by retrieving similar historical incidents.

- 6 How can a RAG system help with regulatory compliance mapping (e.g., mapping controls to ISO 27001 or PCI DSS clauses)?
- 7 How might RAG improve threat intelligence report generation by pulling from multiple live feeds (CISA advisories, vendor bulletins)?
- 8 What are the benefits of using RAG over a static rule-based system for a security chatbot handling employee security questions?

3. Architecture & Design

- 1 Sketch an end-to-end architecture for a cybersecurity RAG assistant: ingestion, embedding, storage, retrieval, generation, and output.
- 2 How would you keep a RAG knowledge base updated as new CVEs, advisories, or internal policies are published?
- 3 What metadata (source, date, classification level, document type) should be stored alongside each chunk, and why?
- 4 How would you implement access control so a RAG system doesn't leak classified or restricted security documents to unauthorized users?
- 5 What is a hybrid retrieval strategy, and when would you combine keyword search with vector search for security data?
- 6 How would you handle multi-hop questions, e.g., 'Which of our exposed assets are affected by CVE-2024-XXXX and what's the remediation?'

4. Data Sourcing & Preparation

- 1 What cybersecurity document types make good candidates for a RAG knowledge base (standards, advisories, logs, playbooks, threat reports)?
- 2 How would you preprocess and clean CISA advisories or vendor security bulletins before embedding them?
- 3 How do you handle highly structured content, like tables in PCI DSS or NIST 800-53, so retrieval doesn't lose context?
- 4 What challenges arise when ingesting real-time threat intel feeds (STIX/TAXII) into a RAG pipeline?
- 5 How would you deduplicate near-identical CVE descriptions from multiple vendor sources?

5. Evaluation & Quality

- 1 How would you evaluate the retrieval quality of a cybersecurity RAG system (e.g., precision@k, recall@k)?
- 2 How would you test whether generated answers are grounded in retrieved sources and not hallucinated (faithfulness/groundedness)?
- 3 Design a test set of question-answer pairs to evaluate a RAG system built on the OWASP Top 10.
- 4 What metrics would you track in production to detect retrieval drift as your threat intel corpus grows stale?
- 5 How would you measure latency trade-offs between retrieval depth (top-k) and answer accuracy in a live SOC tool?

6. Security Risks of RAG Systems Themselves

- 1 What is a prompt injection attack, and how could a malicious document in the knowledge base trigger one?
- 2 How could an attacker poison a RAG system's vector database with crafted documents to manipulate its answers (data/knowledge poisoning)?
- 3 What is the risk of sensitive data leakage through RAG-generated answers, and how would you mitigate it?
- 4 How would you defend a RAG pipeline against retrieval of malicious or spoofed 'advisory' documents from an untrusted feed?
- 5 What logging and monitoring would you put around a RAG system to detect abuse or jailbreak attempts?
- 6 How does least-privilege access control apply to the retrieval layer of a RAG system handling sensitive security data?

Prepared as a study / project reference. Adapt questions to your specific tools (e.g., LangChain, LlamaIndex, specific vector DB) and threat model.